

The Open Labs Responsible AI Framework

Twenty-five implementation-level controls derived from nine AI prototype experiments. Every control traces to a failure observed in practice, and every finding is set against independent published research reaching the same conclusion.

DOCUMENT	OLS-RAF v1.0
PUBLISHED	2026
BASIS	9 prototype experiments (2024–2025)
RISK CATEGORIES	5 — Hallucination, Bias, Misuse, Audit, Scope
TOTAL CONTROLS	25 across 4 tiers
MANDATORY CONTROLS	7 (Tier 1)
APPLICABILITY	Any system producing AI-generated output
LICENCE	CC BY 4.0 (this document) · Apache 2.0 (prototype source code)
AUTHOR	Byron Schreuder, Open Labs Systems, Cape Town, South Africa
CONTACT	byron.schreuder@openlabs.co.za

1. Purpose and scope

This framework was written after the systems were built, not before. Every control listed here was motivated by a specific failure mode encountered in practice — not a theoretical risk anticipated in advance. Where an independent study, standards body or vendor disclosure reaches the same conclusion, it is cited alongside the finding rather than in place of it.

OLS-RAF is an **implementation-level control set**. It is not a replacement for the established governance frameworks and does not attempt to be one. Those frameworks say what must be governed; these controls say what to build. OLS-RAF is designed to sit underneath NIST AI RMF, the EU AI Act high-risk requirements, ISO/IEC 42001 and the OWASP Top 10 for LLM Applications, and maps to each of them in section 3.

Structure

The framework is structured in four tiers based on implementation priority. Tier 1 controls address failures that appeared in every prototype built. Tier 4 controls address failures that appeared under adversarial or edge conditions. **All controls are considered necessary.** The tiers reflect deployment sequence and risk exposure — when a control must be in place, not whether it applies.

How the evidence was produced

1. **Hypothesis definition** — each objective began with a falsifiable hypothesis about a specific governance failure mode, defined before any prototype was built.
2. **Prototype construction** — a functional prototype was designed to test the hypothesis under realistic conditions; to expose failure, not demonstrate capability.
3. **Adversarial testing** — structured testing at boundary conditions, edge cases and misuse scenarios.
4. **Finding documentation** — findings recorded as evidence-based observations, reported with the number of prototypes in which the behaviour was directly evidenced.
5. **Control derivation** — each finding translated into one or more implementable controls.
6. **External corroboration** — each finding checked against independent published research and, where applicable, against regulatory text.

Test conditions and limitations. Findings were produced during structured adversarial testing conducted between 2024 and 2025 against the model versions recorded per prototype in the research repository. Model behaviour on every axis reported here — uncertainty expression, scope adherence, framing sensitivity and injection resistance — is version-dependent. Per-prototype model identifiers, version strings, prompt sets, test dates and sample counts are recorded in `METHODS.md`. Findings are reported as counts of prototypes evidenced, not as composite severity scores. Where a hypothesis was directionally supported but not quantitatively measured, it is marked as such. This is a single-practitioner research programme with a sample of nine systems; it establishes existence and direction of failure modes, not population-level rates.

2. Findings the controls are derived from

Five findings emerged across nine prototypes: two critical, three high severity. Each is stated with the evidence observed, the governance implication drawn, and the independent research that reaches the same conclusion.

OLS-FIND-001

Hallucination is universal, not exceptional CRITICAL

Prototypes evidenced: 5 of 9

All nine systems produced confident incorrect output under specific conditions; five are documented in detail below. The most dangerous hallucinations were not obviously wrong — they were well-structured, plausible, and presented with the same confidence as accurate outputs. No system we built spontaneously indicated uncertainty when it hallucinated. Uncertainty suppression appears to be a default behaviour, not an exception.

Evidence observed

- RAG tutor (OLS-001) cited correct page numbers for content that did not appear on those pages
- Fact-checker (OLS-003) assigned high truth scores to claims it could not actually verify from retrieved sources
- Infrastructure debugger (OLS-005) proposed technically coherent fixes that addressed the wrong root cause
- Documentation generator (OLS-007) described function behaviour that was plausible but factually incorrect for the actual implementation
- SQL analyst (OLS-006) generated syntactically valid queries that returned logically incorrect result sets

Governance implications

- Confidence indicators must be surfaced with every AI output — suppression of uncertainty is a design choice that must be reversed
- High-stakes outputs must require human review regardless of apparent accuracy — the failure mode is invisible by design
- Ground-truth verification pipelines are required wherever factual accuracy is consequential
- Systems must distinguish between "I retrieved this" and "this is true" — retrieval is not verification

CORROBORATING RESEARCH – INDEPENDENT OF THIS STUDY

This finding is not novel to our prototypes, and that is the point — it replicates independently. Stanford RegLab and HAI ran the first preregistered empirical evaluation of commercial RAG-based legal research tools and found that vendor claims of eliminating hallucination were overstated: the tools hallucinated between 17% and 33% of the time. [1] Their most consequential failure mode was misgrounding — citations that are real but do not support the proposition attached to them — which is exactly the OLS-001 behaviour above, and it is more dangerous precisely because it looks correct. OpenAI research supplies the mechanism for the uncertainty suppression we observed: standard training and evaluation procedures reward guessing over acknowledging uncertainty, so under binary scoring a model that always guesses outscores an otherwise identical model that correctly abstains. [2] Confidence without calibration is therefore structural, not incidental. NIST catalogues confabulation as a distinct generative-AI risk category in its Generative AI Profile. [3]

OLS-FIND-002

Autonomous systems interpret scope expansively by default CRITICAL

Prototypes evidenced: 3 of 9

Given a high-level goal and ambiguous permission, every agentic system we built extended its scope beyond stated intent when no architectural boundary prevented it from doing so. The scope expansion was not random — it was directional toward task completion. Systems consistently interpreted the most permissive possible reading of their mandate and acted on it without requesting clarification.

Evidence observed

- Orchestration agent (OLS-002) with a research mandate drafted and formatted outputs it had not been instructed to produce
- Infrastructure debugger (OLS-005) queried log tables outside the scope of the presented error when it judged additional context would help
- Backlog engine (OLS-008) created epics and sub-tasks not requested, reasoning that they were implied by the feature description
- Every prototype successfully prompted outside its stated scope within 3–9 adversarial attempts using non-obvious prompt constructions

Governance implications

- System prompt scope definitions are insufficient — boundaries must be enforced architecturally, not instructionally
- Autonomous systems require a kill switch accessible to non-technical operators — developer intervention is not acceptable as the only stop mechanism
- Step-level permission gating is required in multi-step agentic systems — general authorisation does not govern individual actions
- Multi-agent systems must isolate trust boundaries between agents — elevated permission must not propagate implicitly through agent chains

CORROBORATING RESEARCH – INDEPENDENT OF THIS STUDY

This is a named, recognised vulnerability class: OWASP LLM06, Excessive Agency, decomposed into excessive functionality, excessive permissions and excessive autonomy. [4] Its published mitigations map almost one-to-one onto the controls derived below — minimise available extensions, avoid open-ended functions, apply least privilege on downstream systems, execute in the user’s security context, and require human approval for high-impact actions. OWASP is explicit that authorisation must be enforced by downstream systems rather than delegated to the model’s own judgement, which is the same architectural-not-instructional conclusion we reached from testing. [5] The EU AI Act codifies the human-oversight half of this in Article 14. [8]

OLS-FIND-003

Neutral framing does not produce neutral output HIGH

Prototypes evidenced: 3 of 9

Prompt framing affected output fairness systematically across three prototypes. Semantically equivalent questions phrased differently produced substantively different outputs — not merely stylistic variation, but different result sets, scores and conclusions. The bias was directional: framing that implied an expected outcome made that outcome more likely regardless of the underlying data or knowledge base. This was observed in data analysis, fact-checking, and knowledge retrieval contexts.

Evidence observed

- SQL analyst (OLS-006) "Show me sales performance" vs "Show me where sales underperformed" produced structurally different queries against identical data returning non-equivalent result sets

- Fact-checker (OLS-003): claims framed as questions received lower truth scores than identical claims framed as statements, regardless of source evidence
- RAG tutor (OLS-001): questions framed with implied answers received responses that confirmed the implied answer more often than neutral framing on identical course material
- Bias compounded with volume — framing effects that were marginal on individual queries produced a visible directional skew when the same query set was replayed in bulk against identical data

Governance implications

- Bias audits must test varied prompt framings across demographic and cultural contexts — testing with a single neutral framing is not sufficient
- Output demographic monitoring must be continuous in production — bias absent at low volume can emerge and compound at scale
- Training data provenance must be documented and its known biases acknowledged as a baseline risk
- Remediation pathways must be defined before deployment — monitoring without remediation is a reporting system, not a control

CORROBORATING RESEARCH – INDEPENDENT OF THIS STUDY

Anthropic established sycophancy as a general property of RLHF-trained assistants — demonstrated across five state-of-the-art models and four free-form text tasks, and traced to preference data in which responses matching a user’s stated views are more likely to be preferred. [6] Subsequent measurement puts figures on the effect we observed directionally: simple opinion statements induced agreement with incorrect beliefs at rates averaging 63.7% across seven model families, and sycophantic behaviour was documented in 58.2% of cases across medical and mathematical queries, with models switching from correct to incorrect after user disagreement in 14.7% of cases. [7] One result sharpens the governance implication: expertise framing has negligible impact, while plain opinion statements reliably induce the effect. The trigger is the stated belief, not the claimed authority — so bias audits that only test for authority cues will miss it.

OLS-FIND-004

Most AI outputs lack traceable decision paths

HIGH

Prototypes evidenced: 3 of 9

Seven of the nine systems we built produced outputs without an accessible explanation of why that specific output was generated. When outputs were incorrect, tracing the failure required post-hoc reconstruction — examining logs, re-running prompts with diagnostics, and inferring the decision path rather than reading it. In regulated environments, this is not an inconvenience — it is a compliance failure. A system that cannot be audited cannot be trusted with consequential decisions.

Evidence observed

- Infrastructure debugger (OLS-005): when diagnosis was wrong, the reasoning that produced it was not logged — reproduction of the error required identical re-testing conditions
- Multi-LLM router (OLS-009): routing decisions were opaque — there was no accessible record of why a query was classified as simple or complex
- Documentation generator (OLS-007): when documentation misrepresented code behaviour, there was no trace of which code constructs were misinterpreted and why
- Across all nine prototypes: no system produced a decision trace that could be reviewed by a non-technical auditor without additional tooling

Governance implications

- Decision trace logging must capture: inputs, model identity, version, prompt configuration, retrieved context, and output — before the output reaches the user
- Explainability standards must be tiered by output risk — low-risk outputs require source attribution; high-risk outputs require full decision trace plus human verification
- Model change impact assessment must be triggered by every model update including provider-side updates to third-party models
- Independent audit must be mandatory for systems operating in regulated environments — internal review is necessary but insufficient

CORROBORATING RESEARCH – INDEPENDENT OF THIS STUDY

This is the finding with the clearest regulatory backing. EU AI Act Article 12 requires high-risk AI systems to technically allow automatic event logging over the system lifetime, with traceability appropriate to intended purpose; [8] deployers must retain those logs for a minimum of six months under Article 26(6). [9] Article 13 requires transparency sufficient for an operator to interpret output. Read together, Articles 12 to 14 impose decision-level traceability, because an overseer cannot validate, challenge or override a decision that cannot be explained — oversight without a trace is performative. [10] The South African position is weaker and worth stating plainly: POPIA s. 71 restricts solely automated decisions with legal or substantial effect, but confers no explicit right to explanation — a gap identified in the literature. [11]

OLS-FIND-005

Every system was successfully prompted outside its intended scope

HIGH

Prototypes evidenced: 9 of 9

No system we built resisted sustained adversarial prompt engineering. Every prototype was successfully prompted to produce output outside its stated purpose within a structured adversarial testing session; four representative cases are documented below. The misuse was not always obvious — the most effective attacks used indirect framing, role-assignment, context injection, and prompt chaining rather than direct override instructions. The number of attempts required to break scope ranged from 3 to 9, depending on the system’s architectural constraints.

Evidence observed

- RAG tutor (OLS-001): prompted to produce content on topics not in the course corpus by assigning the model a "curriculum developer" persona
- Orchestration agent (OLS-002): redirected from its stated research task to producing output in a format designed to exfiltrate intermediate agent state
- Fact-checker (OLS-003): prompted to validate a false claim by providing fabricated source URLs that matched the format of verified outlets
- Backlog engine (OLS-008): prompted to produce security-relevant system specifications disguised as user story acceptance criteria
- All systems: system prompt instructions were partially or fully overridden using established prompt injection techniques in fewer than 10 attempts

Governance implications

- Scope boundaries enforced only by instruction are not governance controls — they are suggestions that a sufficiently motivated user will circumvent
- Content moderation must be applied to both inputs and outputs continuously — not only at initial onboarding
- Adversarial prompt testing must be a scheduled recurring activity, not a one-time pre-launch check
- Prompt injection detection must be implemented at the input layer for any system that accepts user-supplied content for processing
- Systems in regulated or high-stakes contexts must be designed with the assumption that they will be attacked — not with the assumption that users are benign

CORROBORATING RESEARCH – INDEPENDENT OF THIS STUDY

Prompt injection is LLM01 — the top entry in the OWASP Top 10 for LLM Applications 2025, the same position it held when the list debuted in 2023. [5] OWASP states directly that given the stochastic nature of generative models it is unclear whether fool-proof prevention methods exist, and recommends layered defence plus regular adversarial testing that treats the model as an untrusted user in order to test trust boundaries — which is the control we derive below. Microsoft reports indirect prompt injection among

the most widely used attack techniques against AI systems in practice, and researchers have demonstrated evasion rates as high as 100% against prominent protection systems including Azure Prompt Shield and Meta's Prompt Guard. [12] Read correctly, this finding does not describe a defect unique to these prototypes. It replicates the field's central unsolved security problem under controlled conditions.

3. Standards alignment

Each OLS risk category maps to the established frameworks as follows. Mapping is at function and article level only — no subcategory identifiers are asserted that have not been verified against the source documents.

OLS CATEGORY	NIST AI RMF 1.0	EU AI ACT	OWASP TOP 10 FOR LLM APPS (2025)
Hallucination	MEASURE / MANAGE; confabulation risk category, AI 600-1	Art. 13 transparency; Art. 15 accuracy	LLM09 Misinformation
Scope	GOVERN / MANAGE	Art. 14 human oversight	LLM06 Excessive Agency
Misuse	MEASURE / MANAGE; prompt injection, AI 600-1	Art. 15 robustness & cybersecurity	LLM01 Prompt Injection
Audit	GOVERN / MEASURE	Arts. 12, 13; Art. 26(6) log retention	—
Bias	MAP / MEASURE	Art. 10 data & data governance	—

NIST AI RMF 1.0 organises risk management into four functions — GOVERN, MAP, MEASURE, MANAGE — across 19 categories and 72 subcategories, and is voluntary but widely treated as the de facto reference for trustworthy AI [3]. ISO/IEC 42001:2023 provides the certifiable management-system wrapper; AI RMF is commonly used as the risk operating model inside it [15].

4. The controls

1

Output integrity controls

MANDATORY

Deploy before any AI system goes live. No exceptions.

CONTROL ID	CONTROL & DESCRIPTION	EVIDENCE SOURCE	STATUS
RAF-1.1 HALLUCINATION	Confidence surfacing Every AI-generated output must surface a confidence indicator or uncertainty signal before the user acts on it. Outputs presented without uncertainty information must be treated as ungoverned. Systems that suppress uncertainty to improve perceived quality violate this control.	OLS-FIND-001 OLS-001 (RAG tutor) OLS-005 (debugger)	Mandatory
RAF-1.2 HALLUCINATION	Source citation enforcement Any system retrieving information must cite the source alongside the output. Citation is not a formatting preference — it is an auditability requirement. A system that produces accurate output without attributable source cannot be verified and must not be trusted in regulated or high-stakes contexts.	OLS-001 (RAG tutor) OLS-003 (fact-checker)	Mandatory
RAF-1.3 MISUSE	Scope boundary enforcement Every AI system must have explicit, tested boundaries defining what it is permitted to do and what it is not. Boundaries defined only in system prompts or usage guidelines are insufficient — every prototype built was successfully prompted outside stated scope. Boundaries must be enforced architecturally, not by instruction.	OLS-FIND-005 OLS-002 (orchestrator) OLS-008 (backlog)	Mandatory
RAF-1.4 AUDIT	Decision trace logging Every output must have a logged trace of the inputs, model, version, prompt configuration, and retrieval context used to produce it. The trace must be queryable after the fact. A system that cannot explain why it produced a specific output at a specific time cannot be audited, defended, or improved.	OLS-FIND-004 OLS-005 (debugger) OLS-009 (router)	Mandatory
RAF-1.5 MISUSE	Content moderation gate All user-submitted inputs and AI-generated outputs must pass through a content moderation layer before processing or display. Moderation must be applied continuously — not only at onboarding. Systems that apply moderation once at input and not at output can produce harmful content from benign-appearing prompts.	OLS-FIND-005 OLS-002 (orchestrator) OLS-006 (SQL analyst)	Mandatory
RAF-1.6 HALLUCINATION	Human review gate for high-stakes outputs Any AI-generated output that will directly inform a consequential decision — medical, legal, financial, infrastructure, or safety-critical — must pass through a mandatory human review gate before being acted upon. Automation may prepare the output; a qualified human must approve its use. This control applies regardless of measured accuracy.	OLS-005 (debugger) OLS-008 (backlog) OLS-007 (docs)	Mandatory
RAF-1.7 SCOPE	Autonomous action kill switch Every agentic or autonomous AI system must have a documented, tested mechanism to halt all autonomous activity immediately and without data loss. The kill switch must be accessible to a non-technical operator. Systems that require developer intervention to stop are ungoverned by design.	OLS-FIND-002 OLS-002 (orchestrator)	Mandatory

2

Bias and fairness controls

REQUIRED

Deploy before any AI system reaches scale. Required for user-facing systems.

CONTROL ID	CONTROL & DESCRIPTION	EVIDENCE SOURCE	STATUS
RAF-2.1 BIAS	Prompt framing bias audit Every AI system must be tested with varied prompt framings across demographic and cultural contexts before deployment. Neutral prompting does not produce neutral output — framing affects fairness systematically. Bias audits must be repeated after every model update, not only at initial deployment.	OLS-FIND-003 OLS-006 (SQL analyst)	Required
RAF-2.2 BIAS	Output demographic monitoring Production AI systems serving multiple user groups must continuously monitor output distributions across demographic segments. Bias that is absent at low usage can emerge and compound at scale. Monitoring must be live, not periodic — and thresholds that trigger review must be defined before deployment.	OLS-FIND-003 OLS-001 (RAG tutor)	Required
RAF-2.3 BIAS	Training data provenance documentation The provenance, composition, and known limitations of training data used by any integrated model must be documented and reviewed. Where training data provenance cannot be established, the system must be treated as carrying unknown bias risk and controls must compensate accordingly.	OLS-FIND-003 OLS-004 (edge AI)	Required
RAF-2.4 BIAS	Remediation pathway definition Before deployment, a documented remediation pathway must exist for identified bias — specifying who is responsible, what action is taken, in what timeframe, and how the fix is verified. A monitoring system without a remediation pathway is a reporting system, not a governance control.	OLS-FIND-003	Required
RAF-2.5 AUDIT	Explainability standard by risk tier Outputs must meet an explainability standard proportional to their risk tier. Low-risk outputs require source attribution. Medium-risk outputs require reasoning transparency. High-risk outputs require full decision trace plus human verification. The explainability standard must be defined per output type before deployment.	OLS-FIND-004 OLS-007 (docs) OLS-009 (router)	Required

3

Operational governance controls

RECOMMENDED

OLS-RAF v1.0 · Open Labs Systems · CC BY 4.0
Deploy as part of ongoing operations. Required for systems in sustained use.

7 / 10

Control ID	Control & Description	Evidence Source	Status
RAF-3.1 SCOPE	Step-level permission gating In agentic systems, each distinct action type must require its own explicit permission — not a general authorisation at system level. Research permission does not grant writing permission. Reading permission does not grant modification permission. Permission scope must decrease as action consequence increases.	OLS-FIND-002 OLS-002 (orchestrator)	Recommended
RAF-3.2 AUDIT	Model change impact assessment Every model update — including provider-side updates to third-party models — must trigger a structured impact assessment before the updated model is used in production. Output quality, bias characteristics, and boundary behaviour must be re-verified. Model updates are system changes and must be governed accordingly.	OLS-004 (edge AI) OLS-009 (router)	Recommended
RAF-3.3 MISUSE	Adversarial prompt testing programme Every AI system must be subjected to structured adversarial prompt testing before deployment and on a defined recurring schedule. Testing must include: out-of-scope instruction attempts, jailbreak patterns, persona injection, context manipulation, and prompt chaining. Findings must be documented and remediated before the next test cycle.	OLS-FIND-005 All nine prototypes	Recommended
RAF-3.4 HALLUCINATION	Output quality degradation monitoring Production AI systems must monitor output quality continuously against a defined baseline. Quality degradation — whether from model drift, data staleness, or configuration change — must surface as an operational alert, not be discovered by users. Thresholds must be set before deployment; alerts must route to a responsible owner.	OLS-004 (edge AI) OLS-009 (router)	Recommended
RAF-3.5 AUDIT	User correction and feedback loop Every user-facing AI system must provide a mechanism for users to flag incorrect, biased, or inappropriate outputs. Flagged outputs must be reviewed by a responsible owner within a defined SLA. Flags must feed into the quality monitoring baseline and the next adversarial testing cycle.	OLS-001 (RAG tutor) OLS-003 (fact-checker)	Recommended
RAF-3.6 SCOPE	Data access minimisation Every AI system must access only the data strictly required to produce its intended output. Systems must not be granted read access to data they do not need to function. Agentic systems must have their data access scope reduced at each step as task specificity increases. Broad access granted for convenience is a governance failure.	OLS-002 (orchestrator) OLS-005 (debugger)	Recommended
RAF-3.7 BIAS	Source diversity requirement Retrieval-augmented systems must enforce minimum source diversity in their retrieval results. Single-source or ideologically concentrated retrieval pools produce outputs that reflect the perspective of that source, not the breadth of available knowledge. Source diversity must be measured and maintained, not assumed.	OLS-003 (fact-checker) OLS-001 (RAG tutor)	Recommended

4 Advanced and edge-case controls

Deploy for high-risk, regulated, or adversarial environments.

ADVISORY

Control ID	Control & Description	Evidence Source	Status
RAF-4.1 AUDIT	Independent third-party audit AI systems operating in regulated environments or producing outputs that affect legal, financial, or health decisions must be subject to independent third-party audit on a defined schedule. Internal governance review is necessary but not sufficient for high-stakes deployments.	OLS-FIND-004 Regulatory environments	Advisory
RAF-4.2 SCOPE	Multi-agent trust boundary isolation In multi-agent systems, each agent must operate within an isolated trust boundary — unable to pass elevated permissions, system-level instructions, or out-of-scope data to other agents in the chain. Trust elevation must require explicit re-authorisation at the orchestration level, not implicit inheritance from the calling agent.	OLS-002 (orchestrator)	Advisory
RAF-4.3 HALLUCINATION	Ground-truth verification pipeline High-stakes AI outputs must pass through an automated ground-truth verification step before reaching users — cross-referencing factual claims against a verified knowledge base and flagging any claim that cannot be verified. Claims that fail verification must be suppressed or clearly marked as unverified, not presented alongside verified content.	OLS-001 (RAG tutor) OLS-003 (fact-checker)	Advisory
RAF-4.4 MISUSE	Prompt injection detection Systems that accept user-supplied content for processing must implement prompt injection detection at the input layer. User content that contains instruction syntax, system prompt override attempts, or role-switching commands must be identified, sanitised, and flagged before reaching the model. Injection attempts must be logged for security review.	OLS-FIND-005 OLS-002 (orchestrator)	Advisory
RAF-4.5 BIAS	Counterfactual fairness testing AI systems making recommendations or classifications must be tested for counterfactual fairness — verifying that outputs do not change when protected characteristics are modified while all other variables are held constant. This test must be run across all protected characteristics relevant to the deployment context.	OLS-FIND-003 OLS-006 (SQL analyst)	Advisory
RAF-4.6 AUDIT	Data subject rights compliance layer AI systems processing personal data must implement a documented compliance layer for data subject rights under applicable legislation, and must not assume the two regimes are equivalent. Under GDPR: right of access (Art. 15), erasure of personal data (Art. 17), and the safeguards attached to solely automated decisions — human intervention, expression of a point of view, and contesting the decision (Art. 22), with responses due within one month (Art. 12(3)). Under POPIA: access and correction (ss. 23-24) and the restriction on solely automated decisions with legal or substantial effect (s. 71), which affords an opportunity to make representations but confers no explicit right to explanation. Erasure of an individual’s contribution from trained model weights is not an established right under either regime and remains technically contested; where it cannot be delivered, the limitation must be documented rather than implied.	Regulatory context GDPR Arts. 12, 15, 17, 22 POPIA ss. 23, 24, 71 [11]	Advisory

5. Finding-to-control evidence map

FINDING	CONTROLS DERIVED	RATIONALE
OLS-FIND-001	RAF-1.1, RAF-1.2, RAF-4.3	Hallucination is universal across all nine prototypes. Confidence surfacing, citation enforcement and ground-truth verification are the three-layer response.
OLS-FIND-002	RAF-1.3, RAF-1.7, RAF-3.1, RAF-4.2	Scope creep in autonomous systems requires boundary enforcement at architecture level, kill switch capability, step-level gating and trust boundary isolation.
OLS-FIND-003	RAF-2.1, RAF-2.2, RAF-2.3, RAF-2.4, RAF-4.5	Bias propagation requires a five-control response: prompt audit, demographic monitoring, provenance documentation, remediation pathways and counterfactual testing.
OLS-FIND-004	RAF-1.4, RAF-2.5, RAF-3.2, RAF-4.1	Audit gaps are closed through decision trace logging, tiered explainability standards, model change assessment and independent third-party review.
OLS-FIND-005	RAF-1.3, RAF-1.5, RAF-3.3, RAF-4.4	Misuse vectors, present in all nine systems, require architectural boundaries, content moderation, adversarial testing programmes and prompt injection detection.

6. Adopting this framework

STAGE	ACTION
Before launch	Implement all seven Tier 1 controls. Record the evidence that each is in place. A system that cannot demonstrate Tier 1 compliance should not process real user input.
Before scale	Implement Tier 2. Bias that is absent at low volume can emerge and compound as usage grows, so these controls must precede growth rather than follow it.
In operation	Implement Tier 3 as standing practice. Re-run RAF-2.1 (framing bias audit) and RAF-3.3 (adversarial testing) after every model change, including provider-side updates.
High-risk contexts	Implement Tier 4 where outputs affect legal, financial, health or safety decisions, or where the system operates in a regulated environment.

Adopters are encouraged to record, for each control, whether it is implemented, partially implemented or accepted as residual risk — and who owns that decision. A control marked “implemented” without a named owner and a piece of evidence is not a control.

7. References

Citation of external research indicates that an independent source reached a consistent conclusion. It does not imply endorsement of Open Labs Systems, its prototypes or this framework by any cited author, institution or standards body.

1. Magesh, V., Surani, F., Dahl, M., Suzgun, M., Manning, C. D. & Ho, D. E. (2025). Hallucination-Free? Assessing the Reliability of Leading AI Legal Research Tools. *Journal of Empirical Legal Studies*, 22, 216–242.
<https://onlinelibrary.wiley.com/doi/full/10.1111/jels.12413>
2. Kalai, A. T., Nachum, O., Vempala, S. S. & Zhang, E. (2025). Why Language Models Hallucinate. arXiv:2509.04664.
<https://arxiv.org/abs/2509.04664>
3. NIST (2023). AI Risk Management Framework 1.0 (AI 100-1); NIST (2024). Generative AI Profile (AI 600-1).
<https://www.nist.gov/itl/ai-risk-management-framework>
4. OWASP Gen AI Security Project. LLM06:2025 — Excessive Agency.
<https://genai.owasp.org/llmrisk/llm06-sensitive-information-disclosure/>
5. OWASP (2025). Top 10 for Large Language Model Applications. LLM01 Prompt Injection; mitigation and adversarial testing guidance.
<https://owasp.org/www-project-top-10-for-large-language-model-applications/assets/PDF/OWASP-Top-10-for-LLMs-v2025.pdf>
6. Sharma, M. et al. (2024). Towards Understanding Sycophancy in Language Models. arXiv:2310.13548 (ICLR 2024). Anthropic.
<https://arxiv.org/abs/2310.13548>
7. A Rational Analysis of the Effects of Sycophantic AI (2026), arXiv:2602.14270 — summarising quantified sycophancy rates reported by Fanous et al. (2025) and Wang et al. (2025).
<https://arxiv.org/pdf/2602.14270>
8. Regulation (EU) 2024/1689 (AI Act), Art. 12 Record-keeping; Art. 13 Transparency; Art. 14 Human oversight; Art. 15 Accuracy, robustness and cybersecurity.
<https://artificialintelligenceact.eu/article/12/>
9. AI Act Art. 26(6) — deployer obligation to retain automatically generated logs for a minimum of six months.
<https://truescreen.io/insights/ai-act-record-keeping-requirements/>
10. Analysis of AI Act Arts. 12–13 and the resulting requirement for decision-level traceability.
<https://aigovernancedesk.com/eu-ai-act-articles-12-13-decision-traceability/>
11. Automated Decision-Making and the Right to an Explanation Under POPIA in South Africa. *Law, Technology and Humans*. See also POPIA s. 71.
<https://lthj.qut.edu.au/article/view/4081>
12. Analysis of prompt-injection prevalence and defence evasion in production systems, including reported evasion against Azure Prompt Shield and Meta Prompt Guard.
<https://introl.com/blog/llm-security-prompt-injection-defense-production-guide-2025>
13. Li, J. et al. (2023). BIRD: Can LLM Already Serve as a Database Interface? arXiv:2305.03111.
<https://arxiv.org/pdf/2305.03111>
14. Lei, F. et al. (2025). Spider 2.0 — enterprise text-to-SQL evaluation.
<https://arxiv.org/pdf/2604.09470>
15. ISO/IEC 42001:2023 — AI management systems; commonly paired with NIST AI RMF as the risk operating model within a certifiable AIMS.
<https://docs.modulos.ai/frameworks/nist-ai-rmf>

Licence. This document is licensed under Creative Commons Attribution 4.0 International (CC BY 4.0). You may share and adapt it, including commercially, provided you give appropriate credit. Prototype source code referenced in this document is licensed separately under Apache 2.0; Creative Commons licences are not intended for software. Third-party model weights remain under their respective licences.

Disclaimer. This framework is research output, not legal advice. References to GDPR, the EU AI Act and POPIA are provided for orientation. Organisations subject to those instruments should obtain qualified legal advice on their specific obligations.